



Firehawk Consulting

The following report was prepared on behalf of SwiftTech.

Thank you for giving Firehawk Consulting the opportunity to review your security posture in anticipation of performing a SOC II security assessment.

We hope you find the notes below as you begin your journey. Please do not hesitate to contact us if you have further questions.

For



SwiftTech



Firehawk Consulting

After review, Firehawk has noted the following areas of concern. You may wish to consider updating policy and security controls based on your current business goals, risk management posture, and compliance considerations.

Controls

Data Storage

- VPC3 File storage supports only AES-128 encryption
- Databases in production environment are unencrypted

End User Management

- Internal Network users require a 7-character password
- Passwords never expire
- VPN access does not require MFA

Network Controls

- TLS v1.1 is used between the cloud production environment and SwiftTech's physical location
- Application development Tiers are not logically segmented from Business Application servers

Patching and Vulnerability Management

- Development Tier servers are unpatched and contain multiple vulnerabilities

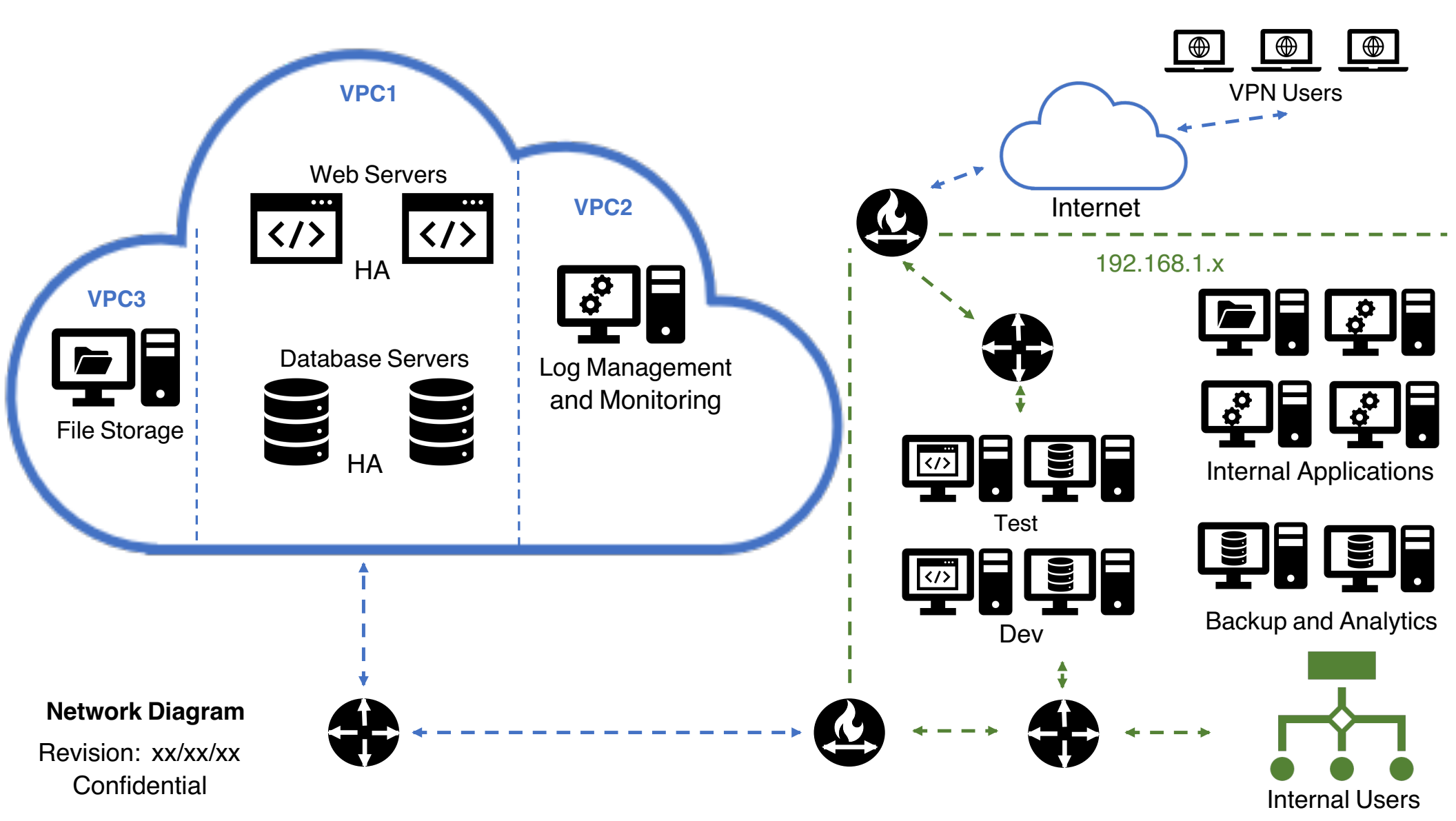
Secure Software Development

- Application code is not scanned for vulnerabilities before being published into production environment



SwiftTech

Speed, Flexibility, Success



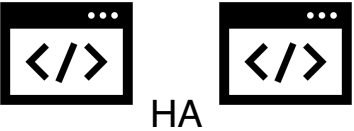
Inputs

- Company Registration
- Company Name
- Company Contact Info
- User Registration
- User Information (Private)
- Role Assignment
- Data Input
- Project Details (Secret)
- Project Timelines
- Related Documentation



Multi-tenant Service

Web Servers



Database Servers



Code

Data

Internal Processing



Test

Backup and Analytics



Processing



- De-identification
- Analysis

Data



Data

Customer Acquisition and Communication



Internal Applications



Data Flow Diagram

Revision: xx/xx/xx
Confidential



SwiftTech

Security Posture (1.)

SwiftTech is the first-to-market provider of technology solutions that improve business efficiency for businesses around the world. The most important reason for their success is their ability to overcome obstacles and do everything they can to develop new ideas as quickly as possible such as their latest product which is a Software as a Service (SaaS) solution that makes project tracking easy and also has a team that strives to improve their security measures because they think about potential risks Seriously like signing service agreements and SOCII reports.

SwiftTech's cyber security risk position is to accept risk because they do not want their product to fail quickly and seek to innovate and develop technology solutions and improve their security measures.



SwiftTech

Relevant Frameworks (2.)

- HIPAA Security Rule : To function with the health care system properly where ensure the confidentiality, integrity, and availability of all e-PHIs they create, receive, maintain, or transmit, identify potential threats, and protect them from reasonably anticipated and impermissible uses or disclosures.
- CIS Control : Basic framework for technology solutions and daily security recipes.
- NCSC CAF : For government in UK that play a vital role in the day-to-day life.



Audit Against Frameworks (3.)

- Choose AES-256 instead of AES-128 to encrypt the storage of VPC3 files.
- Using strong encryption for databases in a production environment.
- Enforce internal network users to have a minimum password length of 15 characters.
- Enforce password change every month.
- Use a defense in depth to access a VPN with an MFA request.



Audit Against Frameworks (3.) pg2 (if needed)

- Use TLS v 1.2 instead of TLS v1.1 due to security issues.
- Application development Tiers are must logically segmented from Business Application servers to reduce the risk of impact on business servers in the event of incidents.
- Unpatched servers are vulnerable and need to be updated immediately.
- Be sure to scan the application code for any vulnerabilities before going into production.



SwiftTech

Governance Mechanisms for End-User Management Controls (6.)

1. Swiftech shall enforce MFA policy for VPN access and enforce defense in depth.
2. Swiftech shall enforce a password policy where the length is 14 characters.
3. Swiftech will change its password every month.